AutomatedLogic Firmware Attack Surface & Detection Brief

AutomatedLogic Firmware Attack Surface & Detection Brief

Scope: Access-verification and PHP-determination pass only (2026-10-22). **No firmware was acquired and no CVE research pass was performed** - stated explicitly rather than presenting an empty table as a finding. AutomatedLogic's documented support entry point (`automatedlogic.com/en/support/`) returns HTTP 404, and the credential endpoint `accounts.automatedlogic.com` returns HTTP 200 carrying a login form. **Access verdict: GATED** - firmware for WebCTRL, LGR-series routers and SE-series controllers is distributed through the AutomatedLogic/Carrier partner channel, not a public download store. Per the standing rule in this project, no attempt was made to register, guess or bypass those credentials. There is therefore **no filename, no byte count and no SHA256 to report** - by finding, not by omission.

php2shell context: this brief's PHP determination was driven by CVE-2026-109618 / CVE-2026-109619 ("php2shell", CVSS 9.2, PHP 5.4+, emergency-patched 2026-10-21). Those two IDs are carried here **as supplied by the requester** - they were not independently corroborated against NVD/MITRE in this pass, and no vendor-specific CVE was invented to pair with them.

PHP finding: UNDETERMINED. WebCTRL's server component is a Java/servlet-container application, which makes a PHP management interface architecturally unlikely - but unlikely is not verified, and without a rootfs this cannot be closed either way. **Do not record AutomatedLogic as in-scope or out-of-scope for php2shell on the strength of this brief.**

Fleet exposure

253 devices in the ARNG OT census (OUI-derived vendor string), function class *Building Automation/BMS*. Staged but empty: `firmware-staging/AutomatedLogic/` (WebCTRL server, LGR routers, SE-series controllers).

What would close the PHP question

1. Partner-portal firmware for one LGR router and one SE-series controller, extracted via `tools/Expand-EatonFirmware.ps1` .
2. Failing that, a live-device check against one of the 253 units: `curl -sI http://<host>/` looking for `X-Powered-By: PHP` , plus a request for a `.php` path to see whether it is handled. This needs no vendor cooperation and is the faster route.
3. A third-party/OSS licence manifest, if Carrier publishes one - that technique definitively answered Axis without its gated binary (see `axis-communications-firmware-threat-brief.md`).

Status

Item	State
Public firmware download	**No** - `accounts.automatedlogic.com` login form (HTTP 200); support path HTTP 404
Firmware acquired	No
Extraction run	N/A
PHP determination	**Undetermined**
CVE research pass	**Not performed** - no CVE IDs asserted here